

Procedimento de Backup e Recuperação

Título: Procedimento de Backup e Recuperação

Versão: 1.0

Data: 06/04/2026

Classificação: Confidencial

1. Objetivo e Âmbito

O presente procedimento estabelece as diretrizes e os requisitos para a realização de cópias de segurança (backups) e para os processos de recuperação de dados e sistemas da [Nome da Organização], em conformidade com os requisitos do Quadro Nacional de Referência para a Cibersegurança (QNRCS) e a Diretiva NIS2.

O objetivo principal é assegurar a disponibilidade, integridade e confidencialidade da informação crítica da organização, permitindo a sua recuperação eficaz e atempada em caso de incidentes, falhas de sistema, perda de dados ou desastres.

Este procedimento aplica-se a todos os sistemas de informação, dados, aplicações e infraestruturas tecnológicas que suportam as operações da [Nome da Organização], bem como a todo o pessoal envolvido na gestão, operação e manutenção destes ativos.

2. Definições

- **Cópia de Segurança (Backup):** Processo de duplicação de dados e/ou sistemas para um local secundário, com o propósito de os proteger contra perda ou corrupção e permitir o seu restauro.
- **Restauro (Recovery):** Processo de recuperação de dados e/ou sistemas a partir de uma cópia de segurança, após um incidente que tenha comprometido a sua disponibilidade ou integridade.
- **RTO (Recovery Time Objective):** Tempo máximo aceitável para o restauro de um sistema ou serviço após uma interrupção, de forma a minimizar o impacto nas operações.
- **RPO (Recovery Point Objective):** Período máximo aceitável de perda de dados que pode ocorrer após um incidente, medido a partir do ponto da última cópia de segurança válida.

- Incidente de Segurança da Informação: Evento adverso, confirmado ou suspeito, relacionado com a segurança da informação que pode comprometer a confidencialidade, integridade ou disponibilidade da informação.
- Local Offsite: Localização física distinta das instalações principais da organização, utilizada para armazenamento de cópias de segurança, protegida contra os mesmos riscos que afetam o local principal.

3. Responsabilidades

As responsabilidades pela implementação e manutenção deste procedimento são as seguintes:

- Conselho de Administração/Direção:
 - * Aprovar a política de backup e recuperação e garantir a alocação de recursos adequados.
 - * Assegurar a revisão anual deste procedimento.
- Gestão de Segurança da Informação (GSI):
 - * Definir e manter este procedimento, garantindo a sua conformidade com as normas e regulamentação aplicáveis.
 - * Monitorizar a eficácia dos processos de backup e recuperação.
 - * Garantir a proteção da confidencialidade, integridade e disponibilidade das cópias de segurança.
- Equipa de Tecnologias de Informação (TI) / Administração de Sistemas:
 - * Executar as cópias de segurança regulares de acordo com as frequências e métodos definidos.
 - * Gerir as ferramentas e plataformas de cópias de segurança e restauro.
 - * Realizar testes periódicos de restauro e documentar os resultados.
 - * Implementar e manter as medidas de proteção das cópias de segurança.
 - * Executar os processos de restauro em caso de incidente.
 - * Manter registos detalhados das cópias de segurança e dos restauros efetuados.
- Proprietários dos Sistemas/Dados:
 - * Colaborar na definição dos RTOs e RPOs para os seus sistemas e dados.
 - * Validar a recuperação dos seus dados e sistemas após os testes de restauro.

4. Política / Procedimento

4.1. Frequência das Cópias de Segurança

As cópias de segurança devem ser realizadas regularmente, de acordo com a criticidade dos dados e sistemas, e em conformidade com os RPOs definidos. (Referência: QNRCS — PR.PI-4, Implementação Processual, Ponto 3)

- Sistemas Críticos (Nível 1):
 - * RPO: A definir, mas não superior a 4 horas.
 - * Frequência: Cópias de segurança incrementais/diferenciais diárias, com cópias de segurança completas semanais.
 - * Exemplo: Bases de dados transacionais, sistemas ERP, sistemas de faturação.
- Sistemas Importantes (Nível 2):
 - * RPO: A definir, mas não superior a 24 horas.
 - * Frequência: Cópias de segurança incrementais/diferenciais diárias, com cópias de segurança completas semanais.
 - * Exemplo: Servidores de ficheiros, servidores de e-mail, aplicações departamentais.
- Sistemas Não Críticos (Nível 3):
 - * RPO: A definir, mas não superior a 72 horas.
 - * Frequência: Cópias de segurança completas semanais ou quinzenais.
 - * Exemplo: Servidores de desenvolvimento, sistemas de teste.
- Documentação da Rede e Sistemas de Informação:
 - * Frequência: Cópias de segurança completas mensais, ou sempre que ocorram alterações significativas.

4.2. Local de Armazenamento das Cópias de Segurança

As cópias de segurança devem ser armazenadas em locais seguros, garantindo a sua proteção contra perdas, danos ou acessos não autorizados. (Referência: QNRCS — PR.PI-4, Implementação Processual, Ponto 1 e 2)

- Armazenamento Local (Onsite):

- * Uma cópia das cópias de segurança mais recentes deve ser mantida em local seguro nas instalações da organização, fisicamente separado dos sistemas de produção, para permitir restauros rápidos e operacionais.

- * Este local deve possuir controlos de acesso físico e ambiental adequados.

- Armazenamento Externo (Offsite):

- * Uma cópia das cópias de segurança completas e das cópias de segurança incrementais/diferenciais mais recentes deve ser guardada em local seguro, fora das instalações principais da organização. (Referência: QNRCS — PR.PI-4, Implementação Processual, Ponto 2)

- * O local offsite deve estar geograficamente distante o suficiente para não ser afetado pelos mesmos desastres que possam atingir as instalações principais (e.g., incêndios, inundações, falhas de energia generalizadas). (Referência: QNRCS — PR.PI-5)

- * O transporte das cópias de segurança para o local offsite deve ser realizado de forma segura, protegendo a confidencialidade e integridade dos dados.

4.3. Proteção das Cópias de Segurança

As cópias de segurança devem ser protegidas contra acessos não autorizados, modificação ou destruição. (Referência: QNRCS — PR.PI-4, Implementação Processual, Ponto 1)

- Confidencialidade: As cópias de segurança devem ser encriptadas, tanto em trânsito como em repouso, especialmente quando armazenadas offsite ou em meios de armazenamento removíveis.
- Integridade: Devem ser implementados mecanismos para verificar a integridade das cópias de segurança (e.g., checksums, hashes) para detetar qualquer corrupção ou alteração.
- Disponibilidade: Devem ser assegurados controlos de acesso rigorosos aos repositórios de cópias de segurança, limitando o acesso apenas a pessoal autorizado.

4.4. Testes Periódicos de Restauro

A organização deve garantir que as suas cópias de segurança podem ser utilizadas e são testadas e validadas regularmente. (Referência: QNRCS — PR.PI-4, Descrição e Implementação Processual, Ponto 4)

- **Frequência dos Testes:** Os testes de restauro devem ser efetuados, no mínimo, trimestralmente, ou sempre que ocorram alterações significativas na infraestrutura ou nos sistemas de backup.
- **Âmbito dos Testes:** Os testes devem abranger uma amostra representativa de sistemas e dados críticos, incluindo a recuperação completa de sistemas, bases de dados e ficheiros.
- **Documentação:** Os resultados dos testes de restauro devem ser documentados, incluindo a data do teste, os sistemas e dados testados, o tempo de recuperação, os problemas encontrados e as medidas corretivas implementadas. (Referência: QNRCS — PR.PI-4, Evidências, Ponto 3)
- **Medidas Corretivas:** Em caso de falha nos testes de restauro, devem ser iniciadas medidas corretivas imediatas para resolver as deficiências identificadas e garantir a usabilidade futura das cópias de segurança.

4.5. Definição de RTO e RPO

A organização deve definir RTOs e RPOs para os seus sistemas e serviços críticos, como parte integrante dos planos de continuidade de negócio e recuperação de incidentes. (Referência: QNRCS — RC.PR-1, Implementação Processual, Ponto 3)

- **RTO:** O RTO para cada sistema ou serviço crítico deve ser estabelecido com base na análise de impacto no negócio, determinando o tempo máximo aceitável de inatividade.
- **RPO:** O RPO para cada sistema ou serviço crítico deve ser estabelecido com base na análise de impacto no negócio, determinando a quantidade máxima aceitável de dados que pode ser perdida.
- **Revisão:** Os RTOs e RPOs devem ser revistos anualmente ou sempre que ocorram alterações significativas nos sistemas ou nos requisitos de negócio.

4.6. Processo de Recuperação de Incidentes

O processo de recuperação de incidentes deve ser sistematizado para garantir uma correta alocação de recursos e a integridade e disponibilidade dos sistemas. (Referência: QNRCS — RC.PR-1, Descrição e Implementação Processual, Ponto 1 e 2)

- **Plano de Recuperação:** A organização deve seguir um plano de recuperação durante ou após um incidente, que inclua os procedimentos detalhados para o restauro de dados e sistemas a partir das cópias de segurança. (Referência: QNRCS — RC.ME-1)

- **Consistência:** As atividades de recuperação devem ser consistentes e transversais a toda a organização e a todos os incidentes, garantindo o rigor, âmbito e aplicabilidade.
- **Coordenação:** O processo de recuperação deve ser coordenado com o plano de resposta a incidentes e o plano de continuidade de negócio da organização.

4.7. Lições Aprendidas e Melhoria Contínua

Após a execução de um plano de recuperação ou de um teste de restauro, devem ser realizadas ações resultantes das lições aprendidas. (Referência: QNRCS — RC.ME-1)

- **Análise Pós-Incidente/Teste:** Deve ser realizada uma análise para identificar o que funcionou bem e o que pode ser melhorado nos processos de backup e recuperação.
- **Atualização de Procedimentos:** Os resultados desta análise devem ser utilizados para atualizar e melhorar este procedimento, os planos de recuperação e as configurações das ferramentas de backup.

5. Controlos e Referências Normativas

Este procedimento aborda os seguintes controlos do QNRCS:

- **PR.PI-4 (Proteção da Informação - Cópias de Segurança):**
 - * **Descrição:** Este procedimento garante que as cópias de segurança podem ser utilizadas e são testadas e validadas regularmente, através da execução de planos de testes de restauro.
 - * **Implementação Processual:** Aborda a proteção da confidencialidade, integridade e disponibilidade das cópias de segurança (4.3), a possibilidade de guardar cópias em local seguro fora das instalações (4.2), a execução de cópias de segurança regulares (4.1) e o teste periódico do restauro (4.4).
 - * **Evidências:** A documentação de suporte a este procedimento, os registos de cópias de segurança e restauro, e os registos de exercícios e testes de reposição servem como evidência.
- **RC.PR-1 (Recuperação - Processo de Recuperação de Incidentes):**
 - * **Descrição:** O procedimento sistematiza o processo de recuperação de incidentes, garantindo a alocação de recursos e a integridade e disponibilidade dos sistemas.
 - * **Implementação Processual:** Inclui a implementação de um processo de recuperação de incidentes (4.6), a garantia de consistência das atividades de recuperação (4.6), e a avaliação prévia das medidas de recuperação (4.5, através da definição de RTO/RPO).

- RC.ME-1 (Recuperação - Lições Aprendidas):
 - * Descrição: O procedimento garante que são executadas ações resultantes de lições aprendidas após a execução do plano de recuperação.
 - * Melhorias: A secção 4.7 detalha o processo de análise pós-incidente/teste e a atualização de procedimentos com base nas lições aprendidas.
- PR.PI-5 (Proteção da Informação - Proteção Física e Ambiental):
 - * Descrição: O procedimento considera a proteção contra desastres naturais ao exigir o armazenamento offsite das cópias de segurança (4.2).

6. Revisão e Aprovação

Este procedimento será revisto anualmente, ou sempre que ocorram alterações significativas na infraestrutura tecnológica, nos requisitos de negócio ou na regulamentação aplicável.

Elaborado por:

[Nome/Departamento]

[Data de Elaboração]

Aprovado por:

[Nome do Responsável pela GSI]

[Cargo]

[Assinatura]

[Data de Aprovação]

Histórico de Revisões:

Versão	Data	Autor(es)	Descrição da Alteração	
:-----	:-----	:-----	:-----	
1.0	06/04/2026	[Nome/Departamento]	Criação inicial do documento.	